记一次芒果 tv 漏洞挖掘#存储型 xss
（基于 SSL 证书+google 语法）

目 录

0x00 这是前言.....3
0x01 信息收集.....4
对目标进行信息收集.....4
0x02 正文开始.....5
第一步.....5
第二步.....5
第三步.....6
正文结束.....7
0x03 没有总结.....8

0x00 这是前言

随缘挖洞，随缘信息收集

干活前洗洗手，漏洞少不了

0x01 信息收集

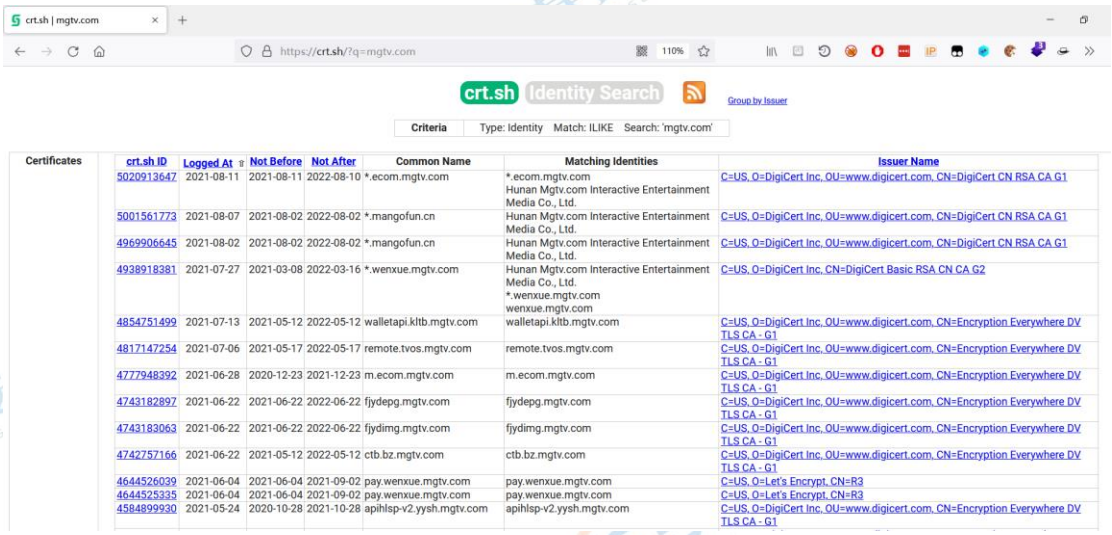
有一说一，新电脑用着真香。

论在只有浏览器和抓包工具的情况下如何做信息收集
（适用场景：网吧等）

对目标进行信息收集

（基于 ssl 证书查询方式+google 语法）

搜索目标单位主域名



crt.sh ID	Logged At	Not Before	Not After	Common Name	Matching Identities	Issuer Name
5020913647	2021-08-11	2021-08-11	2022-08-10	*.ecom.mgtv.com	*.ecom.mgtv.com Hunan Mgtv.com Interactive Entertainment Media Co., Ltd.	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert CN RSA CA G1
5001561773	2021-08-07	2021-08-02	2022-08-02	*.mangofun.cn	Hunan Mgtv.com Interactive Entertainment Media Co., Ltd.	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert CN RSA CA G1
4969906645	2021-08-02	2021-08-02	2022-08-02	*.mangofun.cn	Hunan Mgtv.com Interactive Entertainment Media Co., Ltd.	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert CN RSA CA G1
4938918381	2021-07-27	2021-03-08	2022-03-16	*.wenxue.mgtv.com	Hunan Mgtv.com Interactive Entertainment Media Co., Ltd. *.wenxue.mgtv.com wenxue.mgtv.com	C=US, O=DigiCert Inc, CN=DigiCert Basic RSA CN CA G2
4854751499	2021-07-13	2021-05-12	2022-05-12	walletapi.kltb.mgtv.com	walletapi.kltb.mgtv.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=Encryption Everywhere DV TLS CA - G1
4817147254	2021-07-06	2021-05-17	2022-05-17	remote.tvos.mgtv.com	remote.tvos.mgtv.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=Encryption Everywhere DV TLS CA - G1
4777948392	2021-06-28	2020-12-23	2021-12-23	m.ecom.mgtv.com	m.ecom.mgtv.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=Encryption Everywhere DV TLS CA - G1
4743182897	2021-06-22	2021-06-22	2022-06-22	fjydepg.mgtv.com	fjydepg.mgtv.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=Encryption Everywhere DV TLS CA - G1
4743183063	2021-06-22	2021-06-22	2022-06-22	fjydimg.mgtv.com	fjydimg.mgtv.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=Encryption Everywhere DV TLS CA - G1
4742757166	2021-06-22	2021-05-12	2022-05-12	ctb.bz.mgtv.com	ctb.bz.mgtv.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=Encryption Everywhere DV TLS CA - G1
4644526039	2021-06-04	2021-06-04	2021-09-02	pay.wenxue.mgtv.com	pay.wenxue.mgtv.com	C=US, O=Let's Encrypt, CN=R3
4644525335	2021-06-04	2021-06-04	2021-09-02	pay.wenxue.mgtv.com	pay.wenxue.mgtv.com	C=US, O=Let's Encrypt, CN=R3
4584899930	2021-05-24	2020-10-28	2021-10-28	apihlsp-v2.yysh.mgtv.com	apihlsp-v2.yysh.mgtv.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=Encryption Everywhere DV TLS CA - G1

然后对其中格式为 *.xxx.xxx.xx 的子域名，做进一步信息收集

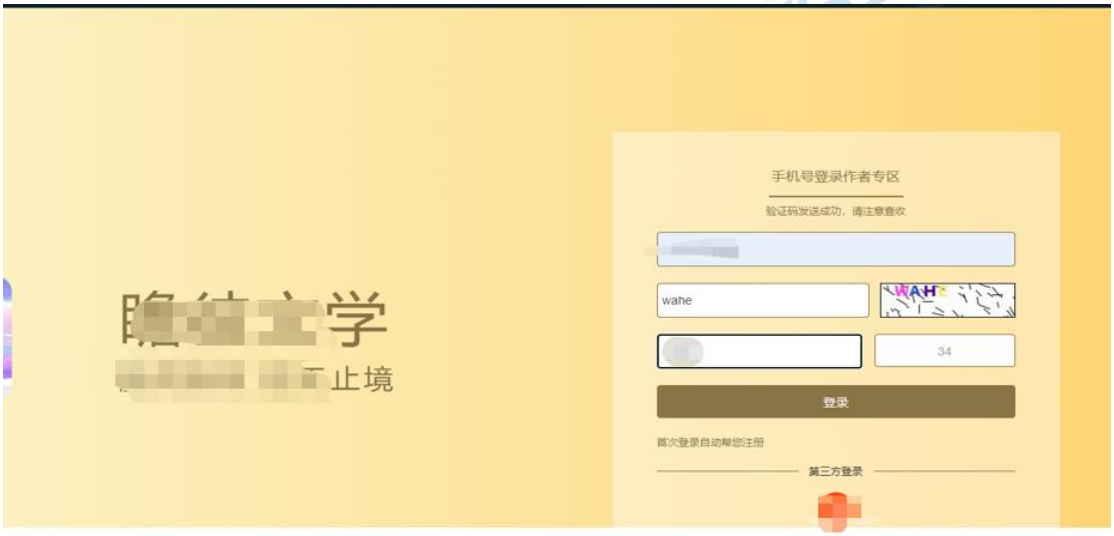
如：site:xxx.xxx.xx （谷歌语法）

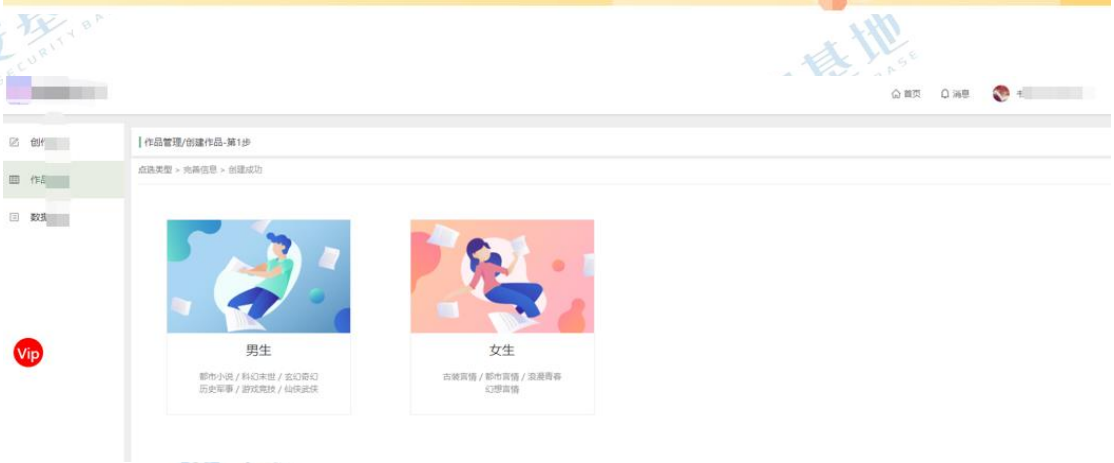
0x02 正文开始

Url：https://aaaaar.wqqque.mgtv.com/

第一步

首先打开该页面发现需要手机号登录作者专区，用我自己的手机号进行了注册

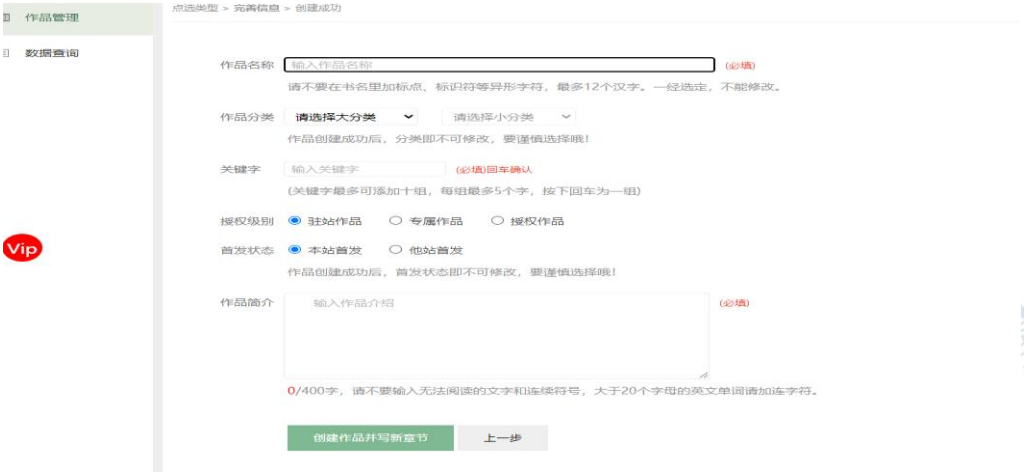




第二步

这时候可以开始你的即兴创作发布一篇文章并抓包去对他的参数进行测试，发现 bookname 存在 xss 跨站脚本攻击

Payload：<img src=x onerror=alert(xx)>



第三步

于是去访问你的文章就会出现 xss 弹框，你只要刷新页面就会出现，所以由此证明是存储型 xss。

正文结束

经过不断的测试发包、修改参数值，发现某站存在越权

0x03 没有总结

测一个网站不要急躁，要静下心来，慢慢的揣测相关功能的请求参数、流程等，（心静了，自然就凉了）

同时也需要细心，持有极度的怀疑去看待每一个请求。